

PENETRATION TESTING REPORT

Mediroza General Hospital

Networkwalks Cybersecurity Internship

Week 4 • Batch B083

Prepared by

Afifa

1. Executive Summary

This report documents the Week 4 penetration testing assessment conducted against the Mediroza General Hospital web application as part of the Networkwalks Cybersecurity Internship. The assessment was performed as a black-box penetration test within the authorized scope provided for the project. The objective was to identify weaknesses in the web application, obtain access to restricted information, recover the contents of protected files, and identify further exposure of confidential information on the client server.

During the assessment, weaknesses in the application's authentication and input-handling mechanisms were identified and investigated. The testing resulted in access to restricted areas of the application and the retrieval of three confidential patient laboratory report PDF files. The recovered files were subsequently analyzed and their encryption was successfully addressed as part of the second milestone.

Further analysis of the information obtained during the assessment led to the discovery of a database backup containing sensitive hospital information. The backup included staff records containing salary and other personal information, as well as shareholder records containing ownership-related details. This demonstrated that the impact of the identified weaknesses extended beyond the initially targeted patient documents.

The findings identified during this assessment represent a significant security and confidentiality risk to the organization. Exposure of patient information, employee records, and shareholder information could result in privacy, financial, reputational, and regulatory consequences. The report documents the observed weaknesses, supporting evidence, risk ratings, and recommended remediation measures.

2. Scope and Methodology

2.1 Scope

The assessment was performed against the authorized Mediroza General Hospital web application as part of the Week 4 Networkwalks Cybersecurity Internship. The objective was to identify security weaknesses that could allow unauthorized access to restricted files or sensitive information.

2.2 Methodology

The assessment began with testing the application's login functionality. SQL injection testing was performed on the authentication mechanism, which resulted in access to three PDF laboratory reports.

The recovered PDF files were encrypted. The files were analyzed and their passwords were successfully recovered using the Networkwalks Network Cracker tool.

Further examination of the target website's `robots.txt` file revealed a location containing a database backup. The exposed database was then reviewed to identify the type of sensitive information contained within it. The database included staff records containing salary information and a separate table containing hospital shareholder details.

The identified findings were documented and supported with screenshots and relevant evidence throughout the assessment.

2.3 Tools Used

The following tools were used during the assessment:

- **Kali Linux** – Used as the primary penetration testing environment.
- **OnlineHashCrack** – Used to analyze and calculate hashes associated with the recovered encrypted PDF files.
- **Networkwalks Network Cracker** – Used to crack the recovered hashes and obtain the passwords required to access the encrypted PDF files.

3. Findings and Proof of Exploitation

3.1 SQL Injection in Login Functionality

During testing of the Mediroza General Hospital login functionality, SQL injection testing was performed on the username input field. The application returned a MySQL syntax error when specially crafted input was submitted, indicating that user-supplied input was being incorporated into a backend SQL query without adequate input handling.

The vulnerability was further tested using a SQL injection payload, which resulted in unauthorized access to the application and allowed three laboratory report PDF files to be obtained.

Evidence

Figure 1: SQL injection error displayed by the application

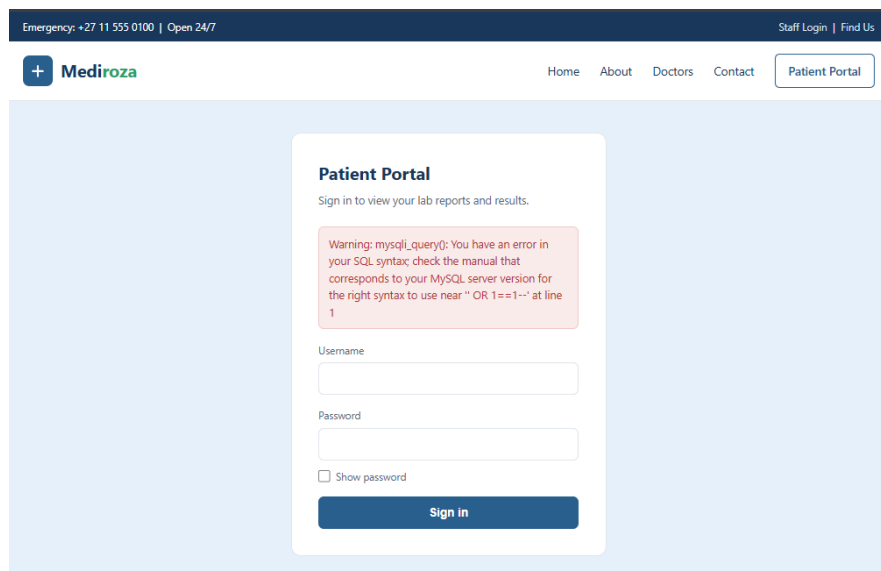
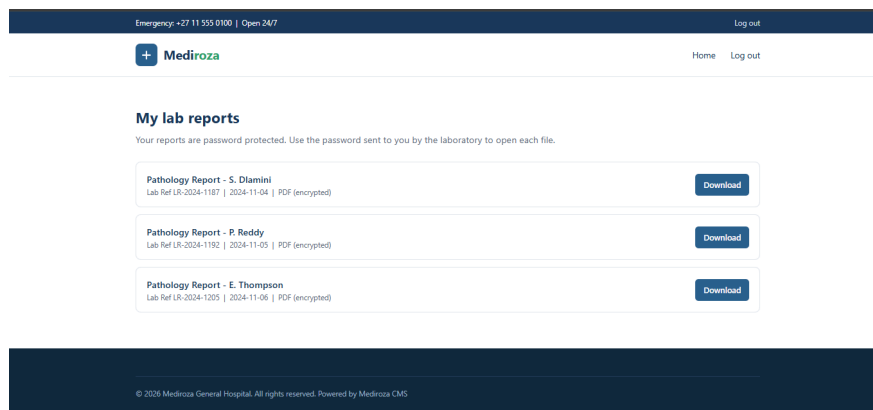


Figure 2: Successful access to the restricted resource



Impact

An attacker could potentially exploit the vulnerable authentication mechanism to bypass normal login controls and gain access to resources that should require authorization. In this assessment, the vulnerability resulted in access to restricted laboratory report files.

3.2 Encrypted PDF Files and Password Recovery

Three PDF laboratory reports were obtained during the assessment. The files were password protected and could not be opened directly.

The hashes associated with the encrypted PDF files were extracted and analyzed using OnlineHashCrack. The recovered hashes were then processed using the Networkwalks Network Cracker, resulting in the recovery of the passwords required to access the protected PDF files.

Evidence

Figure 3: Encrypted PDF files obtained during the assessment

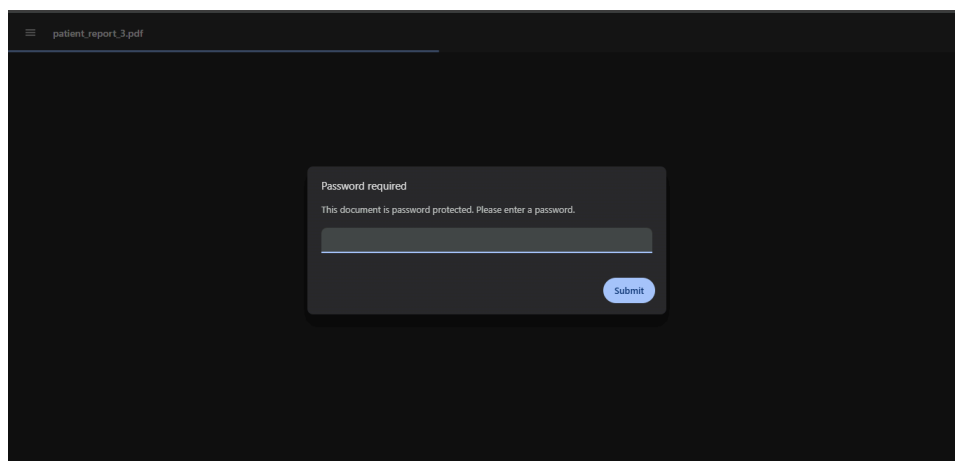


Figure 4: Hash analysis using OnlineHashCrack

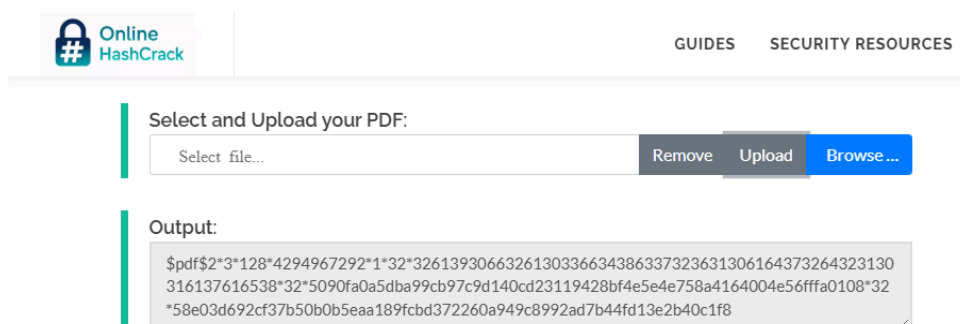


Figure 5: Password recovery using Networkwalks Network Cracker

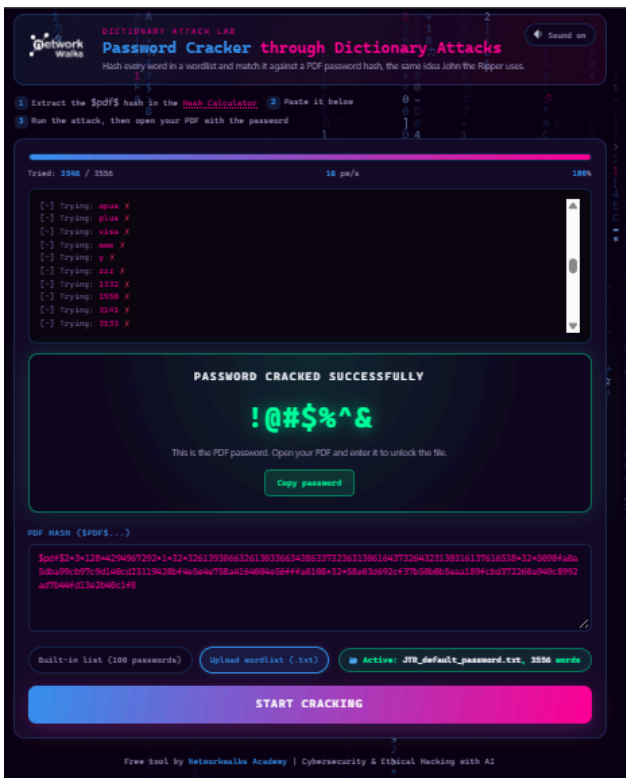


Figure 6: Successfully opened PDF files

Mediroza

General Hospital

14 Cedar Avenue, Johannesburg, South Africa

Tel: +27 11 555 0100

medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name:

Emily Thompson

Patient ID:

MG-P-10258

Date of Birth:

1978-05-03

Gender:

Female

Report Date:

2024-11-06

Referring Dr:

Dr. Ahmed Kara

Specimen:

Serum

Lab Ref No:

LR-2024-1205

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	11.4	g/dL	12.0 - 15.5	LOW
Ferritin	9	ug/L	15 - 150	LOW
TSH	3.1	mIU/L	0.4 - 4.0	Normal
Vitamin D	42	nmol/L	50 - 125	LOW
Fasting Glucose	5.1	mmol/L	3.9 - 5.5	Normal

Reported by: Dr. Rajesh Naidoo, MBChB FCPATH
Mediroza Diagnostics Lab - SANAS accredited pathology laboratory (Ref M0417)
This report is confidential and intended only for the named patient and the referring clinician.
Verified electronically. No signature required. Mediroza CMS 1.4.2

Impact

The successful recovery of the passwords allowed access to the contents of the protected laboratory reports. This demonstrates that the protection applied to the files did not prevent unauthorized access once the files had been obtained.

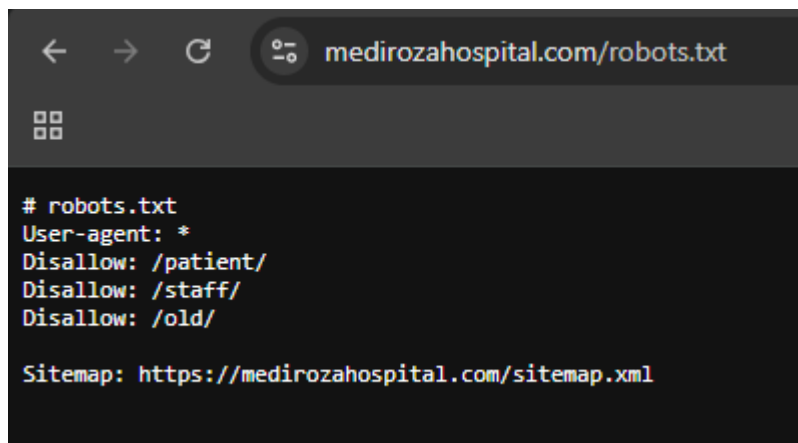
3.3 Exposed Database Backup

Further examination of the target website's `robots.txt` file revealed a reference to a database backup. The backup was accessible through the web application and contained confidential hospital information.

The database backup included a `staff` table containing employee information such as names, job titles, departments, contact details, national identification numbers, monthly salaries, and joining dates. It also contained a `shareholders` table containing shareholder names, percentage ownership, number of shares held, and share class.

Evidence

Figure 7: robots.txt revealing the location of the database backup



```
# robots.txt
User-agent: *
Disallow: /patient/
Disallow: /staff/
Disallow: /old/

Sitemap: https://medirozahospital.com/sitemap.xml
```

Figure 8: Accessible database backup

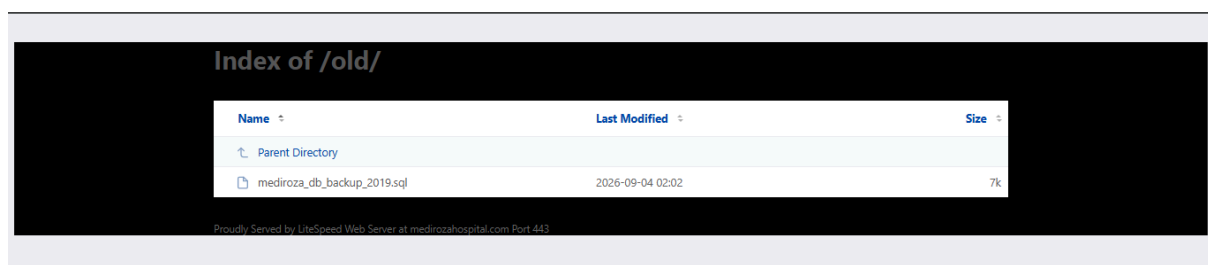


Figure 9: Staff table containing salary and employee information

```
-- mediroza_db_backup_2019.sql
-- Mediroza General Hospital - Internal database backup
-- Generated by Mediroza OMS 1.4.2 backup module
-- Host: localhost Database: mediroza_hr
-- WARNING: contains confidential staff and shareholder records
-- Backup date: 2019-08-27 02:14:03

SET NAMES utf8mb4;
SET FOREIGN_KEY_CHECKS = 0;

--
-- Table structure for table `staff`
--
DROP TABLE IF EXISTS `staff`;
CREATE TABLE `staff` (
  `id` int(11) NOT NULL AUTO_INCREMENT,
  `full_name` varchar(120) NOT NULL,
  `job_title` varchar(120) NOT NULL,
  `department` varchar(80) NOT NULL,
  `email` varchar(120) NOT NULL,
  `phone` varchar(20) NOT NULL,
  `national_id` varchar(20) NOT NULL,
  `monthly_salary_zar` int(11) NOT NULL,
  `date_joined` date NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

--
-- Dumping data for table `staff`
--
LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary_zar`,`date_joined`) VALUES
(1,'Dr. Rajesh Naidoo','Chief Pathologist','Diagnostics Lab','r.naidoo@medirozahospital.com','+27 82 181 2067','85021013011081',130000,'2009-03-16'),
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 102 2014','85031023022082',152000,'2011-07-01'),
(3,'Dr. Johan van der Merwe','Medical Director','Management','j.merwe@medirozahospital.com','+27 82 103 2021','85041033033083',160000,'2007-01-22'),
(4,'Dr. Anita Naicker','Consultant Cardiologist','Cardiology','a.naicker@medirozahospital.com','+27 82 104 2028','85051043044084',132000,'2012-09-10'),
(5,'Dr. Ahmed Kara','Consultant Physician, Internal Medicine','a.kara@medirozahospital.com','+27 82 105 2035','85061053055085',120000,'2013-02-18'),
(6,'Dr. Yusuf Cassin','Senior Registrar','Emergency & Trauma','y.cassin@medirozahospital.com','+27 82 106 2042','85071063066086',70000,'2015-05-04'),
(7,'Michael Roberts','HR Director','Human Resources','m.roberts@medirozahospital.com','+27 82 107 2049','85081073077087',90000,'2010-11-15'),
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 108 2056','85091083088088',32000,'2016-08-23'),
(9,'Jameel Malik','IT Systems Administrator','IT','j.malik@medirozahospital.com','+27 82 109 2063','85101093099089',50000,'2015-04-12'),
(10,'Thabo Molefe','Network Engineer','IT','t.molefe@medirozahospital.com','+27 82 110 2070','85111103110081',40000,'2017-10-02'),
(11,'Nomula Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@medirozahospital.com','+27 82 111 2077','85121113121082',34000,'2016-01-19'),
(12,'Lerato Mokoena','Registered Nurse','Pediatrics','l.mokoena@medirozahospital.com','+27 82 112 2084','85011123132083',33000,'2017-06-07'),
(13,'Bongani Ndlovu','Registered Nurse','Cardiology','b.ndlovu@medirozahospital.com','+27 82 113 2091','85021133143084',35000,'2015-12-01'),
(14,'Zanele Mahlangu','Nursing Sister','Theatre','z.mahlangu@medirozahospital.com','+27 82 114 2098','85031143154085',42000,'2013-03-25'),
(15,'Kagiso Sithole','Pharmacist','Pharmacy','k.sithole@medirozahospital.com','+27 82 115 2105','85041153165086',61000,'2014-09-08'),
(16,'Naledi Zulu','Pharmacy Assistant','Pharmacy','n.zulu@medirozahospital.com','+27 82 116 2112','85051163176087',26000,'2019-02-14'),
(17,'Themba Mkhosi','Radiographer','Radiology','t.mkhosi@medirozahospital.com','+27 82 117 2119','85061173187088',44000,'2016-07-30'),
(18,'Palasa Radebe','Radiographer','Radiology','p.radebe@medirozahospital.com','+27 82 118 2126','85071183198089',43000,'2017-04-11'),
(19,'Deepak Pillay','Lab Technologist','Diagnostics Lab','d.pillay@medirozahospital.com','+27 82 119 2133','85081193209091',41000,'2015-05-20'),
(20,'Kavitha Govender','Lab Technician','Diagnostics Lab','k.govender@medirozahospital.com','+27 82 120 2140','85091203220092',35000,'2018-08-06'),
(21,'Dr. Suresh Moodley','Consultant Radiologist','Radiology','s.moodley@medirozahospital.com','+27 82 121 2147','85101213231093',130000,'2012-02-28'),
(22,'Dr. Fatima Patel','Pediatrician','Pediatrics','f.patel@medirozahospital.com','+27 82 122 2154','85111223242094',41000,'2013-10-17'),
(23,'Misha Singh','Physiotherapist','Rehabilitation','m.singh@medirozahospital.com','+27 82 123 2161','85121233253095',48000,'2016-11-09'),
(24,'Dr. Vikram Chetty','Anaesthetist','Theatre','v.chetty@medirozahospital.com','+27 82 124 2168','85011243264096',135000,'2011-06-13'),
(25,'David Smith','Facilities Manager','Operations','d.smith@medirozahospital.com','+27 82 125 2175','85021253275097',52000,'2014-01-27'),
(26,'Karen O'Connor','Billing Administrator','Finance','k.oconnor@medirozahospital.com','+27 82 126 2182','85031263286098',29000,'2018-03-19'),
(27,'James Wilson','Security Supervisor','Operations','j.wilson@medirozahospital.com','+27 82 127 2189','85041273297099',27000,'2019-09-02'),
(28,'Linda Foudrie','Receptionist','Front Office','l.foudrie@medirozahospital.com','+27 82 128 2196','85051283308001',19000,'2020-02-10'),
(29,'Peter van Wyk','Procurement Officer','Supply Chain','p.wyk@medirozahospital.com','+27 82 129 2203','85061293319002',38000,'2015-08-24'),
(30,'Andile Mbeki','Ward Clerk','Administration','a.mbeki@medirozahospital.com','+27 82 130 2210','85071303330003',21000,'2019-11-05');
UNLOCK TABLES;

SET FOREIGN_KEY_CHECKS = 1;
-- End of backup
```

Figure 10: Shareholders table containing ownership information

```
--
-- Table structure for table `shareholders`
--
DROP TABLE IF EXISTS `shareholders`;
CREATE TABLE `shareholders` (
  `id` int(11) NOT NULL AUTO_INCREMENT,
  `shareholder_name` varchar(120) NOT NULL,
  `share_percent` decimal(5,2) NOT NULL,
  `shares_held` int(11) NOT NULL,
  `share_class` varchar(20) NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

LOCK TABLES `shareholders` WRITE;
INSERT INTO `shareholders` (`id`,`shareholder_name`,`share_percent`,`shares_held`,`share_class`) VALUES
(1,'Dr. Rajesh Naidoo',18.0,180000,'Ordinary'),
(2,'Cedar Health Holdings (Pty) Ltd',15.0,150000,'Ordinary'),
(3,'Dr. Johan van der Merwe',12.0,120000,'Ordinary'),
(4,'Reddy Family Trust',11.0,110000,'Ordinary'),
(5,'Thabo Molefe',10.0,100000,'Ordinary'),
(6,'Sarah Botha',9.0,90000,'Ordinary'),
(7,'Dr. Ahmed Kara',8.0,80000,'Preferential'),
(8,'Naledi Zulu',7.0,70000,'Ordinary'),
(9,'Michael Roberts',6.0,60000,'Ordinary'),
(10,'Dr. Vikram Chetty',4.0,40000,'Preferential');
UNLOCK TABLES;

SET FOREIGN_KEY_CHECKS = 1;
-- End of backup
```

Impact

Exposure of the database backup resulted in unauthorized disclosure of highly sensitive employee and ownership information. The exposed information could create privacy, financial, reputational, and regulatory risks for the organization.

The database backup should not have been accessible through the public-facing web application.

4. Risk Rating

The findings identified during the assessment were assessed based on their potential impact and the level of access or information exposure demonstrated during testing.

Finding	Risk Rating	Justification
SQL Injection in Login Functionality	Critical	The vulnerability allowed the authentication mechanism to be bypassed and resulted in access to restricted laboratory reports.
Encrypted PDF Files and Password Recovery	High	The passwords protecting the recovered PDF files were successfully recovered, allowing access to the information contained within the files.
Exposed Database Backup	Critical	The exposed database backup contained sensitive staff and shareholder information, including salary and ownership-related details.

4.1 Overall Risk

The assessment identified security weaknesses that resulted in unauthorized access to restricted files and exposure of confidential information. The findings demonstrate that weaknesses in authentication, file protection, and access control could have a significant impact on the confidentiality of the organization's information.

5. Recommendations and Remediation

The following recommendations are provided to address the vulnerabilities identified during the assessment and reduce the risk of unauthorized access or disclosure of sensitive information.

5.1 SQL Injection in Login Functionality

1. Use parameterized queries or prepared statements instead of directly incorporating user input into SQL queries.
2. Implement proper input validation and sanitization for all user-supplied input.
3. Configure the application to return generic error messages instead of exposing database errors or SQL syntax details.
4. Use a database account with only the permissions required by the application.
5. Perform regular security testing of authentication and input-handling functionality.

5.2 Encrypted PDF Files and Password Recovery

1. Use strong, unique passwords for protecting sensitive PDF files.
2. Avoid relying on weak or easily recoverable passwords for confidential documents.
3. Use appropriate encryption mechanisms for sensitive files and manage encryption keys securely.
4. Restrict access to confidential laboratory reports through proper authentication and authorization controls.
5. Regularly review the security of password-protected files to ensure that their protection remains effective.

5.3 Exposed Database Backup

1. Remove database backups and other sensitive files from publicly accessible web directories.
2. Store backups outside the web root and restrict access using appropriate server-side permissions.
3. Do not rely on robots.txt to protect sensitive files, as it is not an access-control mechanism.
4. Review the web server configuration to prevent direct access to backup files and other sensitive resources.
5. Regularly audit publicly accessible directories for accidentally exposed files or backups.

6. Conclusion

The penetration testing assessment of the Mediroza General Hospital web application identified multiple security weaknesses that could lead to unauthorized access and disclosure of sensitive information.

The assessment demonstrated successful access to restricted laboratory reports through the application's login functionality, recovery of passwords protecting the PDF files, and discovery of an exposed database backup containing sensitive staff and shareholder information.

The identified vulnerabilities highlight the importance of secure input handling, strong protection of sensitive files, and proper access controls for backup data. Implementing the recommended remediation measures would help reduce the risk of unauthorized access and protect sensitive hospital information.